

Title of Issue

Reflected Cross-Site Scripting (XSS) in HTML Context with No Encoding

Description

The application's search functionality reflects user-supplied input directly into the HTML response without any output encoding or sanitization. When a user submits a search query, the value is echoed back into the page source within an HTML context. Because no characters are encoded, an attacker can inject raw HTML and JavaScript that the victim's browser will execute.

Affected Endpoint: GET /?search=<input> **Vulnerable Parameter:** search

The application renders the search query as:

```
<h1>0 search results for 'PAYLOAD'</h1>
```

Since angle brackets and other HTML special characters are not encoded, a `<script>` tag injected into the `search` parameter is treated as valid HTML and executed by the browser.

Steps to Exploit

1. Navigate to the application's home page and locate the search box.
2. Enter the following payload into the search box:

```
<script>alert(1)</script>
```

3. Submit the search.
4. Observe that an alert dialog box appears in the browser with the value `1`, confirming script execution.

Alternatively, craft the URL directly:

```
https://<lab-id>.web-security-academy.net/?search=<script>alert(1)</script>
```

Proof of Concept

Payload:

```
<script>alert(1)</script>
```

Injected URL:

```
https://<lab-id>.web-security-academy.net/?  
search=%3Cscript%3Ealert%281%29%3C%2Fscript%3E
```

Rendered HTML (excerpt):

```
<h1>0 search results for '<script>alert(1)</script>'</h1>
```

The browser parses the `<script>` tag as a valid HTML element and executes its contents, displaying an alert with value `1`.

Impact

- **Session hijacking** — attacker can steal session cookies via `document.cookie` if the `HttpOnly` flag is not set.
- **Credential theft** — inject a fake login overlay to capture user credentials.
- **Malware distribution** — redirect victims to attacker-controlled sites hosting drive-by downloads.
- **Defacement** — modify page content seen by the victim.
- **CSRF bypass** — XSS can be used to perform actions on behalf of authenticated users.
- Effective payload delivery requires tricking a victim into clicking a crafted URL (phishing, email campaigns).

Mitigation / Remediation

1. **Encode all user-supplied output** before rendering into HTML — use HTML entity encoding for all characters (`<` → `<`, `>` → `>`, `"` → `"`, etc.).
2. **Implement a strict Content Security Policy (CSP)** that blocks inline scripts: `Content-Security-Policy: default-src 'self'`.
3. **Use modern frameworks** (React, Angular, Vue) that auto-escape output by default.
4. **Validate input on the server side** — reject input containing HTML special characters in contexts where they serve no legitimate purpose.
5. **Set the `HttpOnly` flag** on session cookies to prevent JavaScript access.

CVSS Score

CVSS v3.1 Score: 6.1 (Medium) CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Delivered via a crafted URL over the internet
Attack Complexity	Low	No special conditions required
Privileges Required	None	No authentication needed to craft the payload
User Interaction	Required	Victim must click a crafted link
Scope	Changed	Script executes in victim's browser, outside the server
Confidentiality Impact	Low	Can access cookies and page data
Integrity Impact	Low	Can modify page content in victim's browser
Availability Impact	None	No denial of service